

Security Risk Assessment Tool

Application Version: 3.6

Remediation Report

06-17-2026

DISCLAIMER

The Security Risk Assessment Tool at <http://HealthIT.gov> is provided for informational purposes only. Use of this tool is neither required by nor guarantees compliance with federal, state or local laws. Please note that the information presented may not be applicable or appropriate for all health care providers and organizations. The Security Risk Assessment Tool is not intended to be an exhaustive or definitive source on safeguarding health information from privacy and security risks. For more information about the HIPAA Privacy and Security Rules, please visit the HHS Office for Civil Rights Health Information Privacy website at: <http://www.hhs.gov/ocr/privacy/hipaa/understanding/index.html>

NOTE: The NIST, HICP, and HPH CPG standards provided in this tool are for informational purposes only as they may reflect current best practices in information technology and are not required for compliance with the HIPAA Security Rule's requirements for risk assessment and risk management. This tool is not intended to serve as legal advice or as recommendations based on a provider or professional's specific circumstances. We encourage providers and professionals to seek expert advice when evaluating the use of this tool. Updated 7/29/2025

Section 1, SRA Basics

Q1. Has your practice completed a security risk assessment (SRA) before?

Answer: No.

Education: Performing a security risk assessment periodically will help safeguard the confidentiality, integrity, and availability of ePHI. Consider scheduling a vulnerability scan to assist in identification of technical vulnerabilities to improve your risk assessment.

References

HIPAA: §164.308(a)(1)(ii)(A)
NIST CSF: ID.RA, ID.AM, GV.OC, PR.DS, PR.PS, RS.MI
HPH CPG: 1 HICP: TV1 - Practice # 7, 10

Remediation Activities:

This is the organization's first formal HIPAA Security Risk Assessment, currently being completed using the HHS SRA Tool. Going forward, the SRA will be repeated at least annually and after any significant change to systems, vendors, or ePHI flows, as required by our Security Management & Risk Management Policy (TM#SEC#POL#001, §4.1) and the Security Policy & Procedure Management Process (TM#SEC#PROC#001). Identified deficiencies are tracked to closure in this Remediation Report with assigned owners and due dates. We will also schedule a technical vulnerability scan to strengthen identification of technical risks and feed the results into the next assessment.

Owner: Raja Gopalan **Due Date:** 06-30-2026 **Date Completed:** 06-16-2026

Q5. How do you verify that that your security measures comply with current HIPAA requirements?

Answer: We review our practice's Security Policies and Procedures and keep up to date on relevant guidance regarding protection of ePHI through listservs or other security publications.

Education: Security risk analysis is a foundational component of identifying and assessing ePHI risks and vulnerabilities in your practice. An accurate and thorough security risk assessment should be performed, reviewed, and updated periodically or in response to operational changes, security incidents, or the occurrence of a significant event. Additionally, consistently monitoring changes or updates to cybersecurity guidance related to ePHI protection will ensure you are aware of current requirements.

References

HIPAA: §164.308(a)(1)(ii)(B)
NIST CSF: GV.RR, GV.PO, GV.OV, GV.RM HPH CPG: 1
HICP: TV1 - Practice # 10

Remediation Activities:

Compliance with current HIPAA requirements is verified through our documented program rather than informal monitoring alone: (1) all security and privacy policies are reviewed at least annually, and on any regulatory or operational change, per the Security Policy & Procedure Management Process (TM#SEC#PROC#001); (2) risks are re#assessed at least annually and after any significant change per the Security Management & Risk Management Policy (TM#SEC#POL#001); (3) information#system activity and audit logs are reviewed per the Audit Controls policy (TM#SEC#POL#009); and (4) we monitor HHS/OCR and NIST guidance (e.g., NIST SP 800#66r2) to stay current. Findings feed back into policy updates and into this Remediation Report. The full policy set was reviewed and approved 2026#06#16; the next scheduled review/ verification is 2027#06#16.

Section 2, Security Policies

Section 3, Security & Workforce

Q19. What is included in your sanction policy to hold personnel accountable if they do not follow your security policies and procedures?

Answer: Formal written documentation of the sanction and the reason for the sanction.

Education: Consider which sanction policies and procedures are reasonable and appropriate for your organization in order to hold personnel accountable if they do not follow your security policies and procedures.

References

HIPAA: §164.308(a)(1)(ii)(C)
NIST CSF: PR.AT, RS.CO,
PR.PS HPH CPG: N/A HICP: N/A

Remediation Activities:

Owner:

Due Date:

Date Completed:

Section 4, Security & Data

Section 5, Security and the Practice

Section 6, Security and Business Associates

Section 7, Contingency Planning

Q6. What types of emergencies have you considered?

Answer: We have considered natural disasters, such as wildfire, damaging winds, floods, hurricanes, tornadoes, or earthquakes.

Education: You should consider infrastructure and man-made disasters that could affect the confidentiality, integrity, and availability of ePHI.

References

HIPAA: §164.308(a)(7)(i) NIST
CSF: GV.OC, GV.RM, PR.AA,
PR.IR, PR.PS, RS.MA, ID.RA
HPH CPG: 7, 19 HICP: N/A

Remediation Activities:

Owner:

Due Date:

Date Completed:

Q9. How does your practice prevent, detect, and respond to security incidents?

Answer: We have a security incident response plan documented in our policies and procedures.

Education: Consider testing the security incident response plan periodically using a documented process. The incident plan should cover broad categories of incidents to prepare for. Testing the incident plan is an effective means of preparation and training. Describe requirements for users to report suspicious activities in the organization and for the cybersecurity department to manage incident response.

References

HIPAA: §164.308(a)(6)(i) NIST
CSF: DE.AE, RS.CO, RC.CO,
PR.PS, RS.IP HPH CPG: 7, 18,
19 HICP: TV1 - Practice # 8

Remediation Activities:

Owner:

Due Date:

Date Completed: